



Vom Konzept zur Umsetzung: Einführung des Microsoft Enterprise Access Models

Thomas Naunheim
Cyber Security Architect
@glueckkanja AG



Thomas Naunheim

Cyber Security Architect @glueckkanja AG
Microsoft MVP (Identity & Access, Cloud Security)

Live in Koblenz/Lahnstein, Germany



cloud-architekt.net



Naunheim.cloud



thomasnaunheim



Thomas_Live

Vielen Dank an unsere Sponsoren!

Diamond



Platinum



Gold



Silber

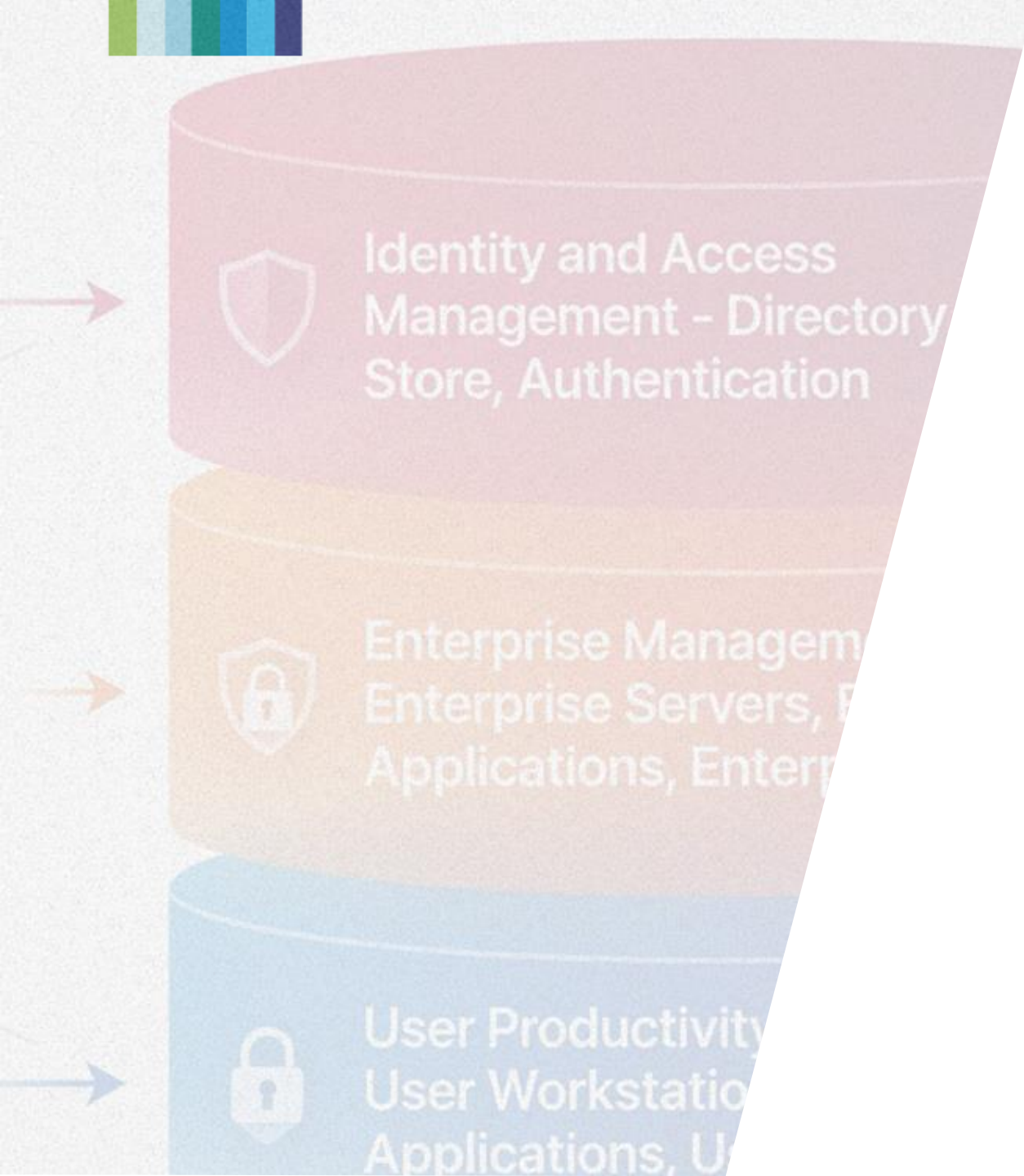




Agenda

1. Introduction to Enterprise Access Model
2. Identify Control Plane access in Microsoft Cloud
3. Apply protection on privileges in Entra ID
4. Integration of EntraOps to Microsoft XDR/SIEM
5. Monitor privileged access paths

Demo
EntraOps



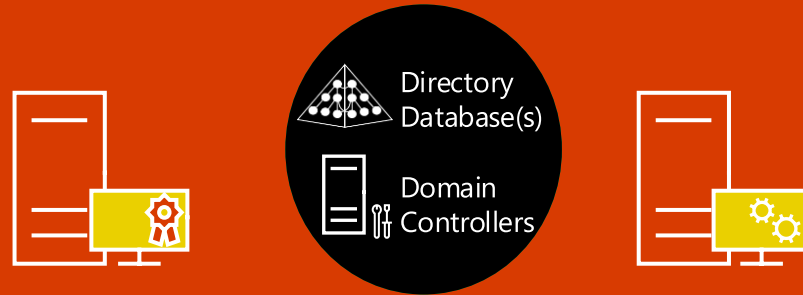
Introduction to Enterprise Access Model (EAM)

ESAE Tiering Model in 2000s-2010s

Active Directory / On-Premises

Tier 0 (Identity)

Domain &
Enterprise Admins



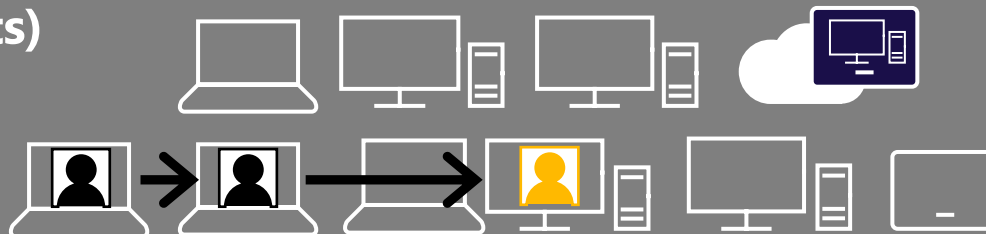
Tier 1 (Server)

Server Admins



Tier 2 (Clients)

Workstation &
Device Admins



Azure AD / Cloud Services?

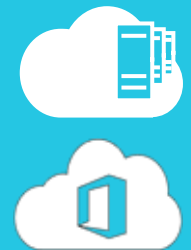
Tier 0 (Identity)

Global Admins
Authenticator Admin



Tier 1 (Resources)

VM Contributor (IaaS)
Exchange Admin (SaaS)

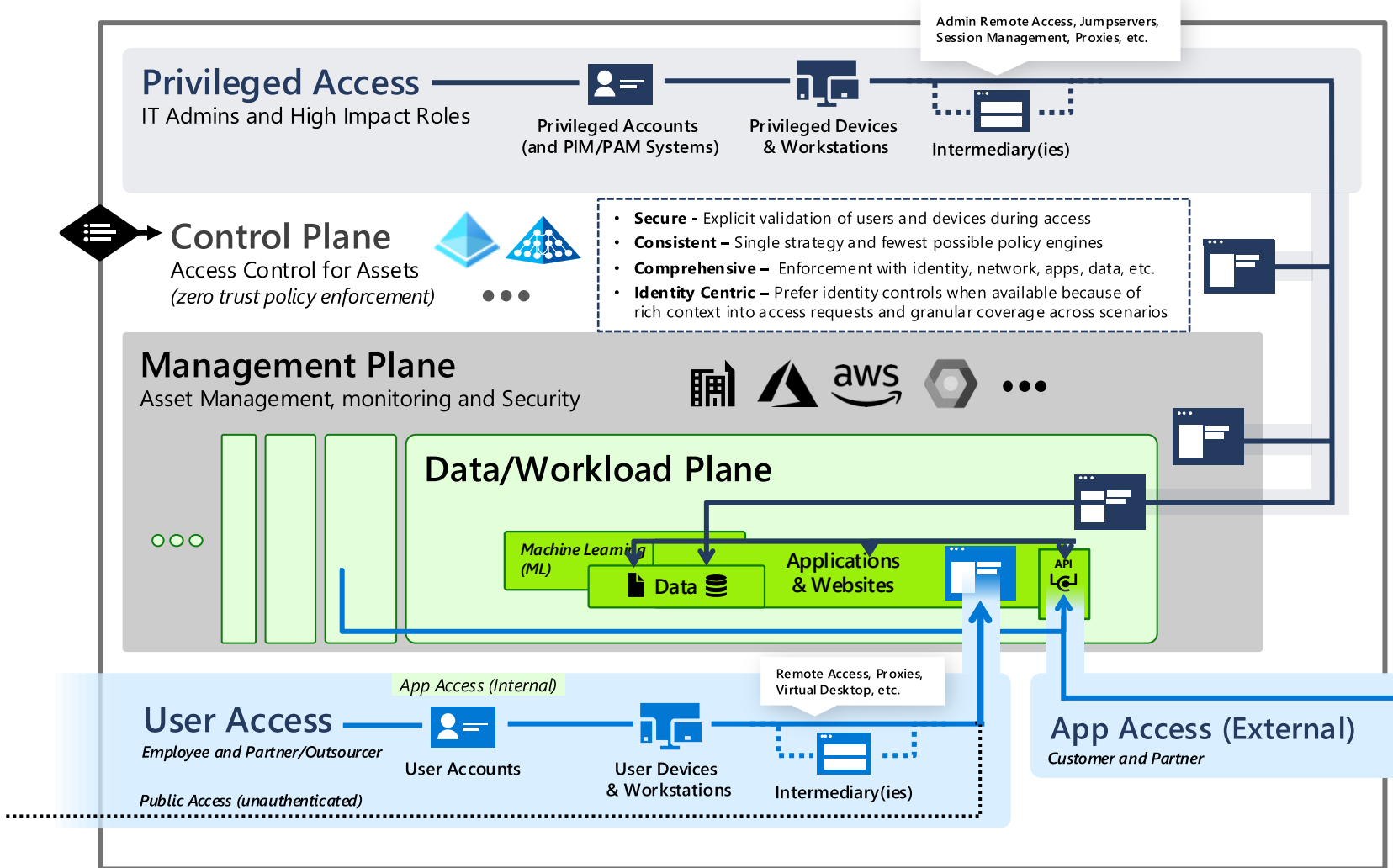


Tier 2 (Endpoints)

Intune Service Admin?
AADJ Device Local Administrator?



Enterprise Access Model



Privileged Access

Enables IT administrators and other high impact roles to access to sensitive systems and data.
Stronger security for higher impact accounts

Control and Management Planes

Provide unified access and management for workloads and assets (*and provide attackers shortcut for illicit objectives*)

Data/Workloads

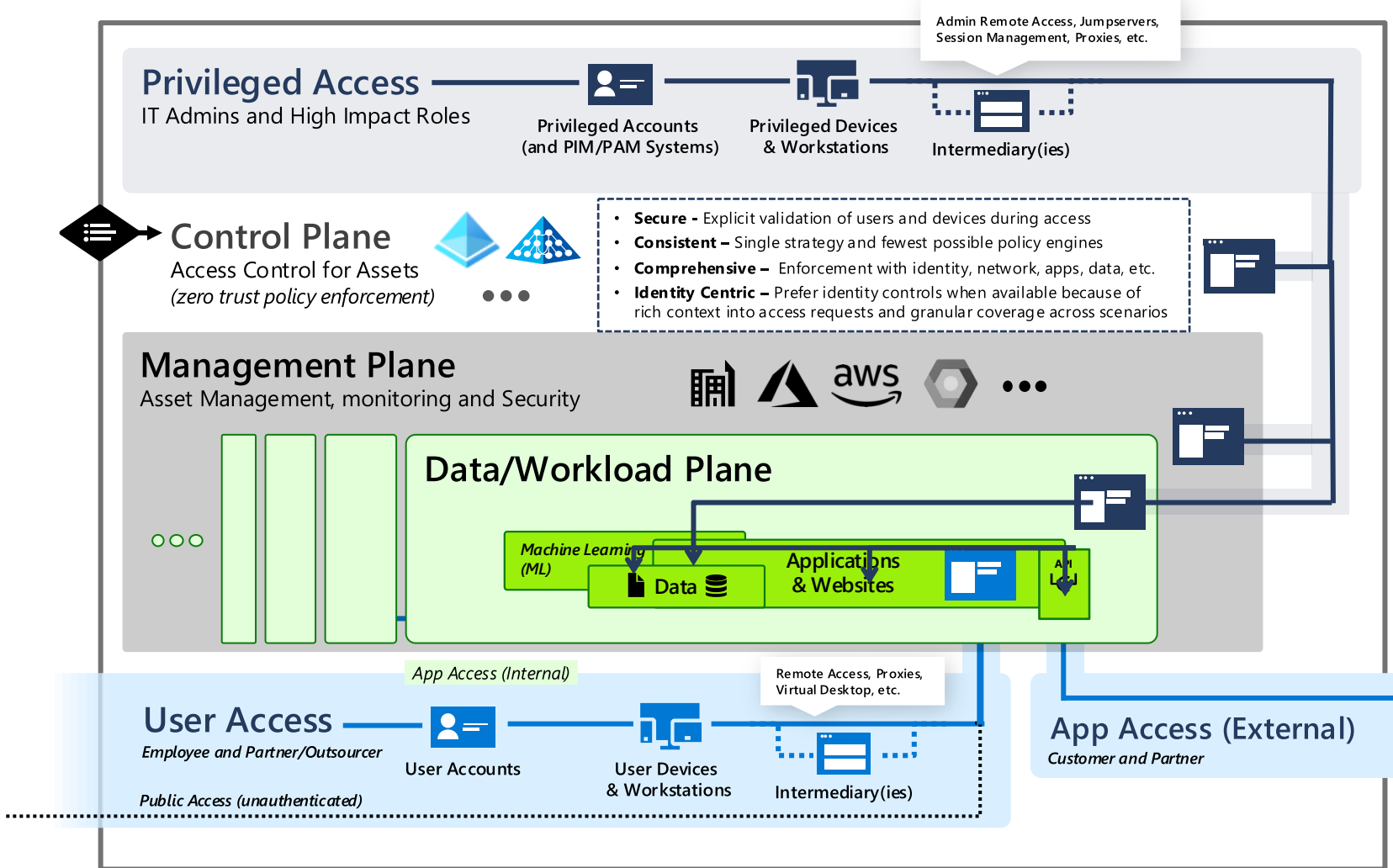
Create and store business value in

- Business processes (in apps/workloads)
- Intellectual property (in data and apps)

User and App Access

How employees, partners, and customers access these resources

Enterprise Access Model



Privileged Access

Enables IT administrators and other high impact roles to access to sensitive systems and data.
Stronger security for higher impact accounts

Control and Management Planes

Provide unified access and management for workloads and assets (*and provide attackers shortcut for illicit objectives*)

Data/Workloads

Create and store business value in

- Business processes (in apps/workloads)
- Intellectual property (in data and apps)

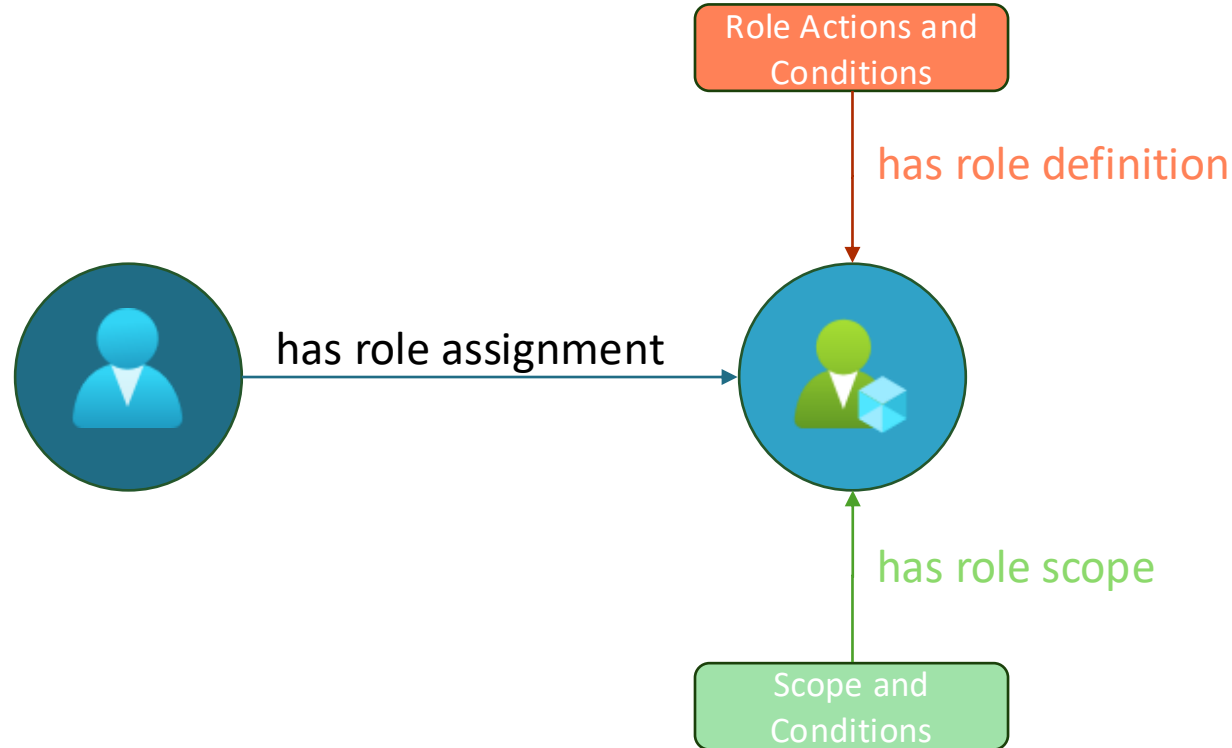
User and App Access

How employees, partners, and customers access these resources

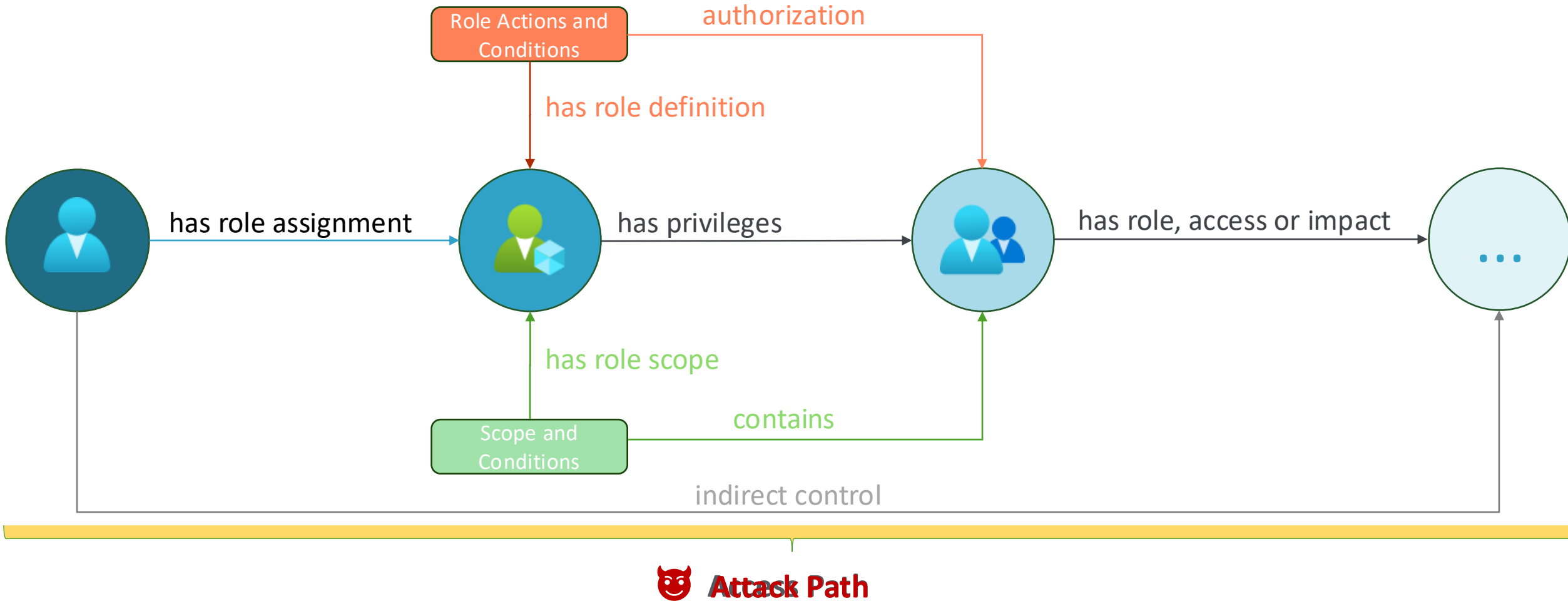


Identify Control Plane access

Delegation and Control Relationship



Delegation and Control Relationship



Wer wird Control Plane Admin?

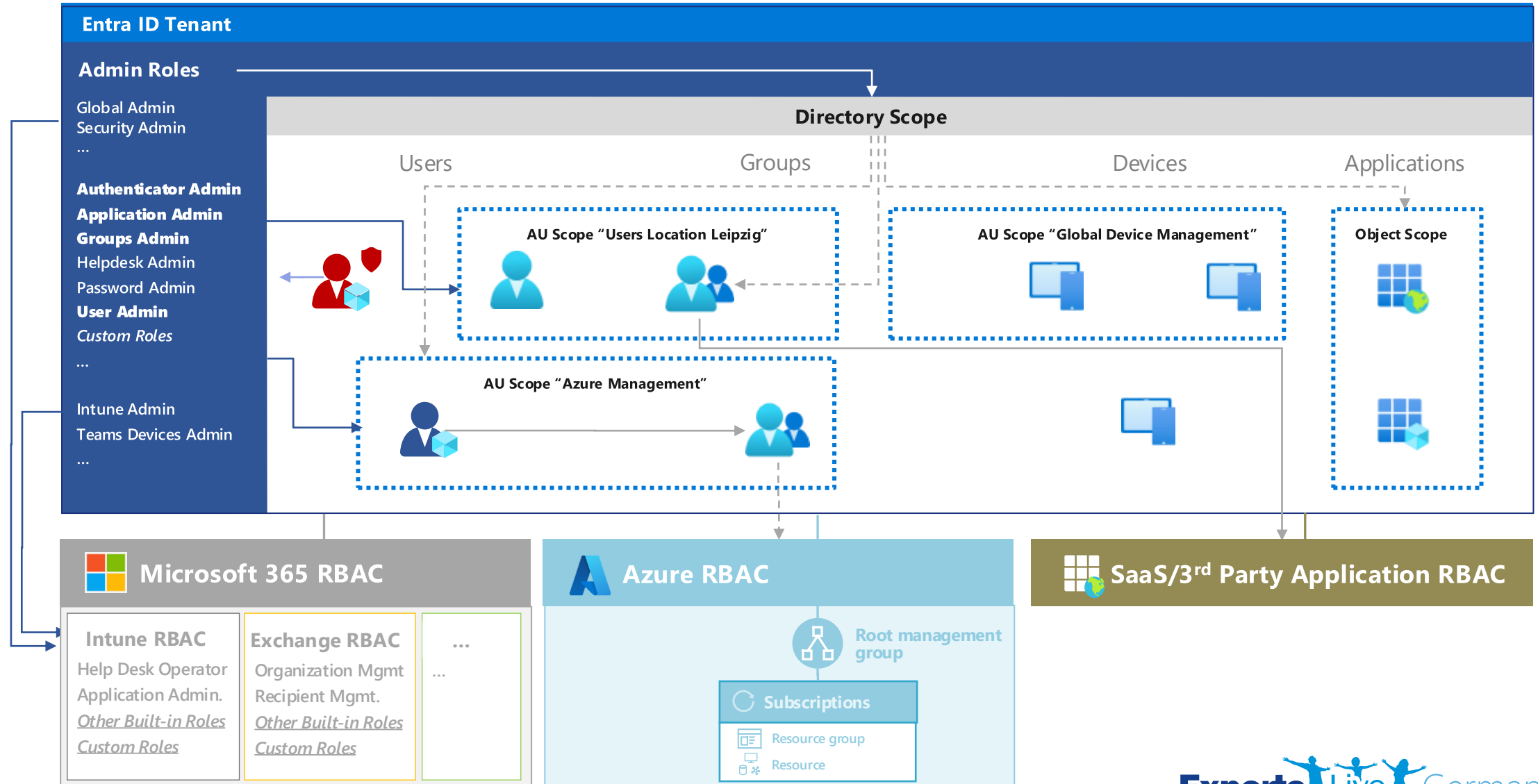
**WHICH OF THESE
DIRECTORY ROLES ARE TIER0?**

- A. Authenticator Administrator
- B. Cloud Application Administrator
- C. Groups Administrator
- D. User Administrator

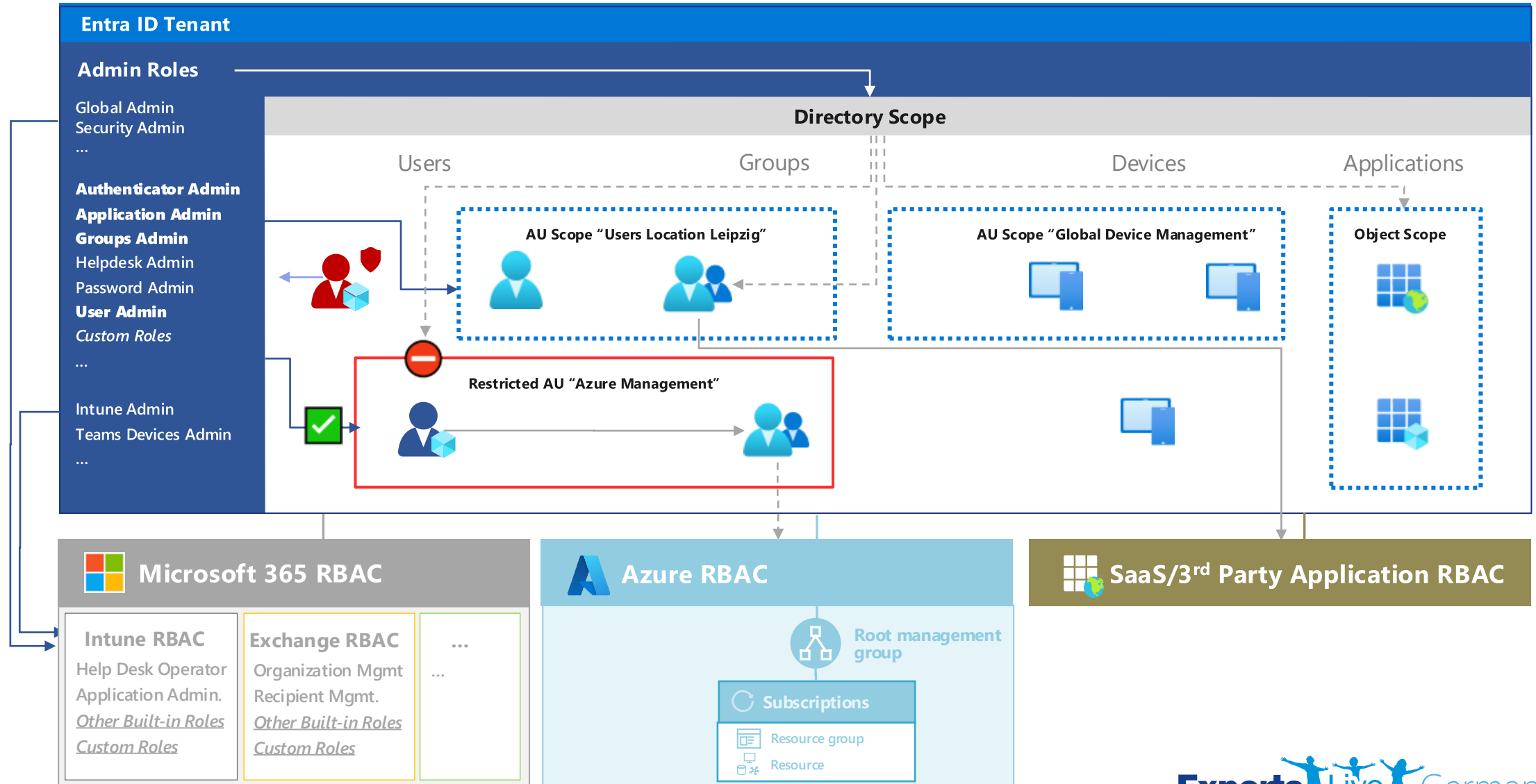


"It Depends"

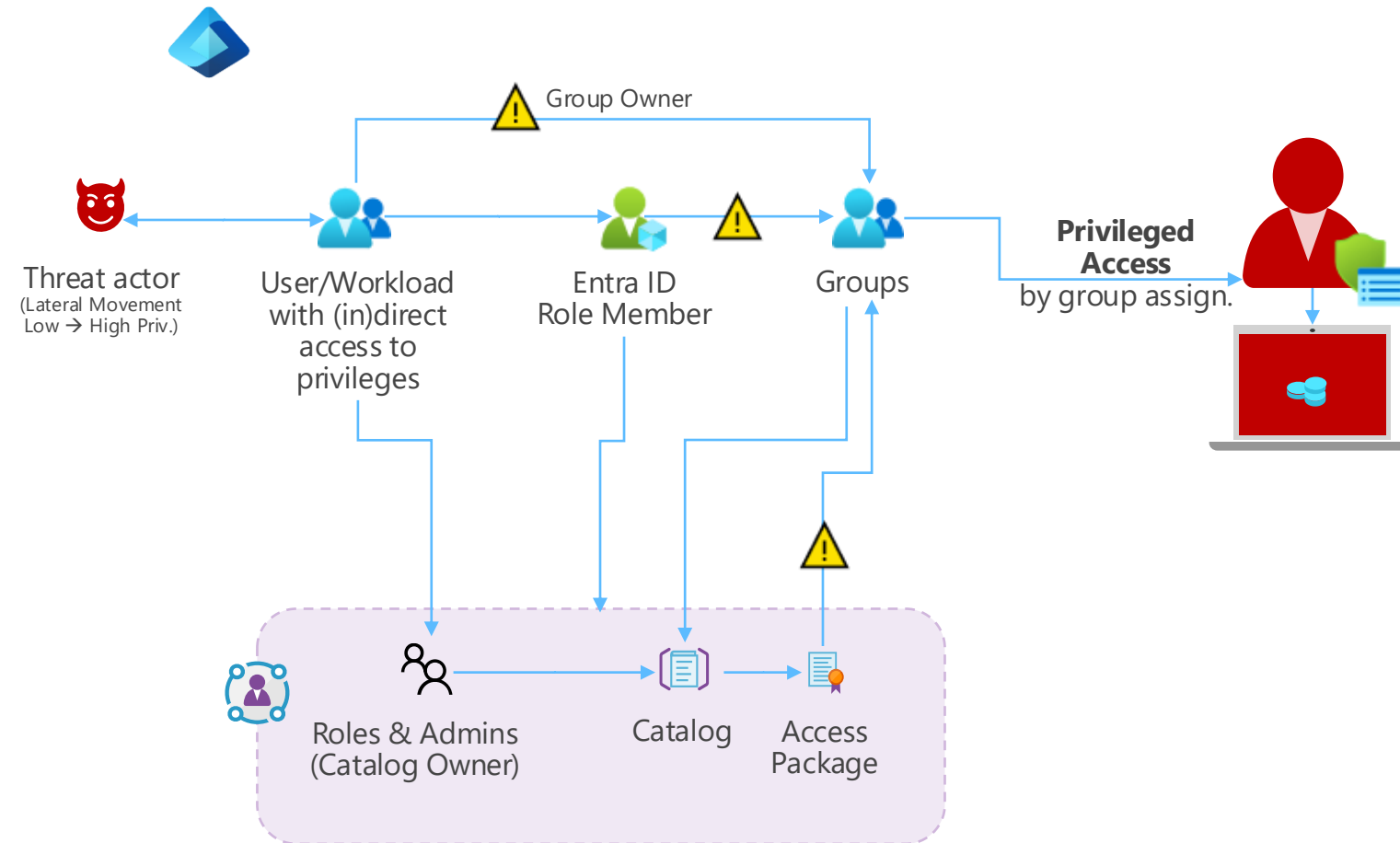
Scope and Delegation



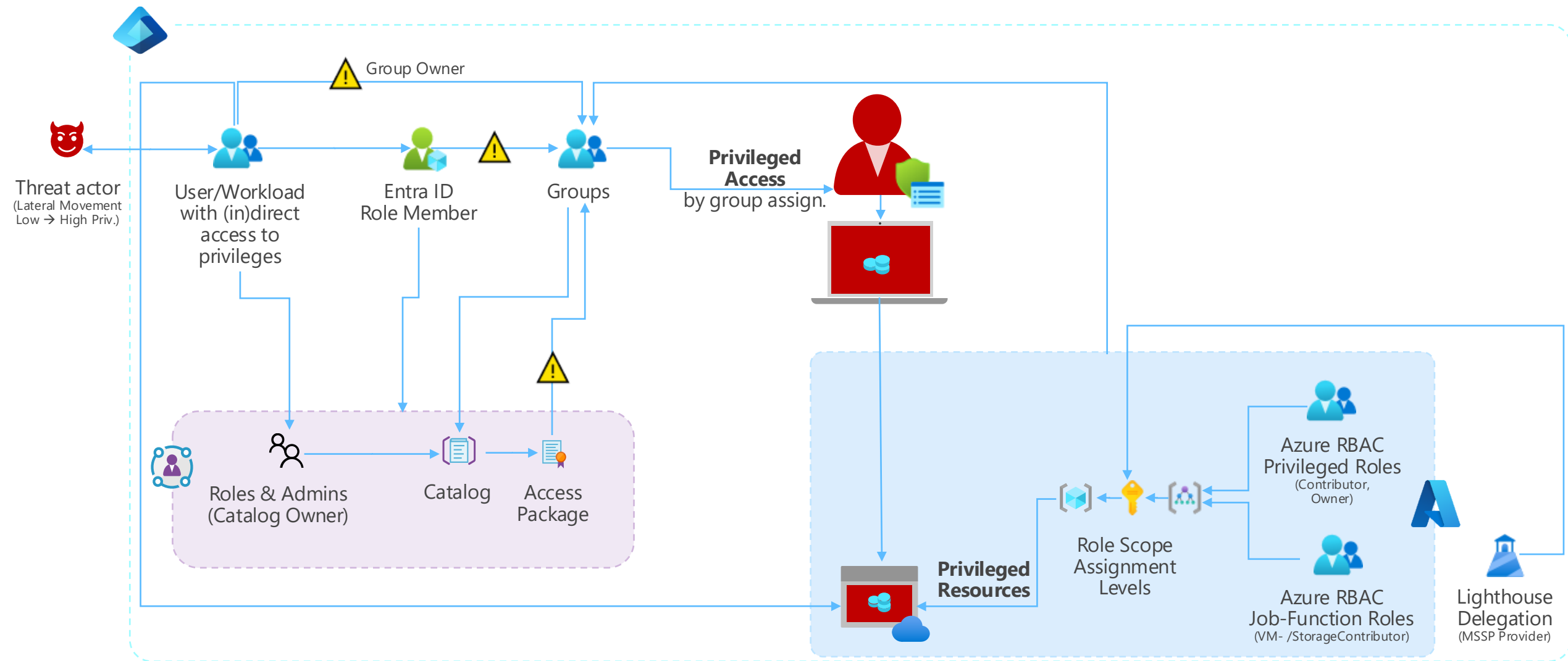
Scope and Delegation



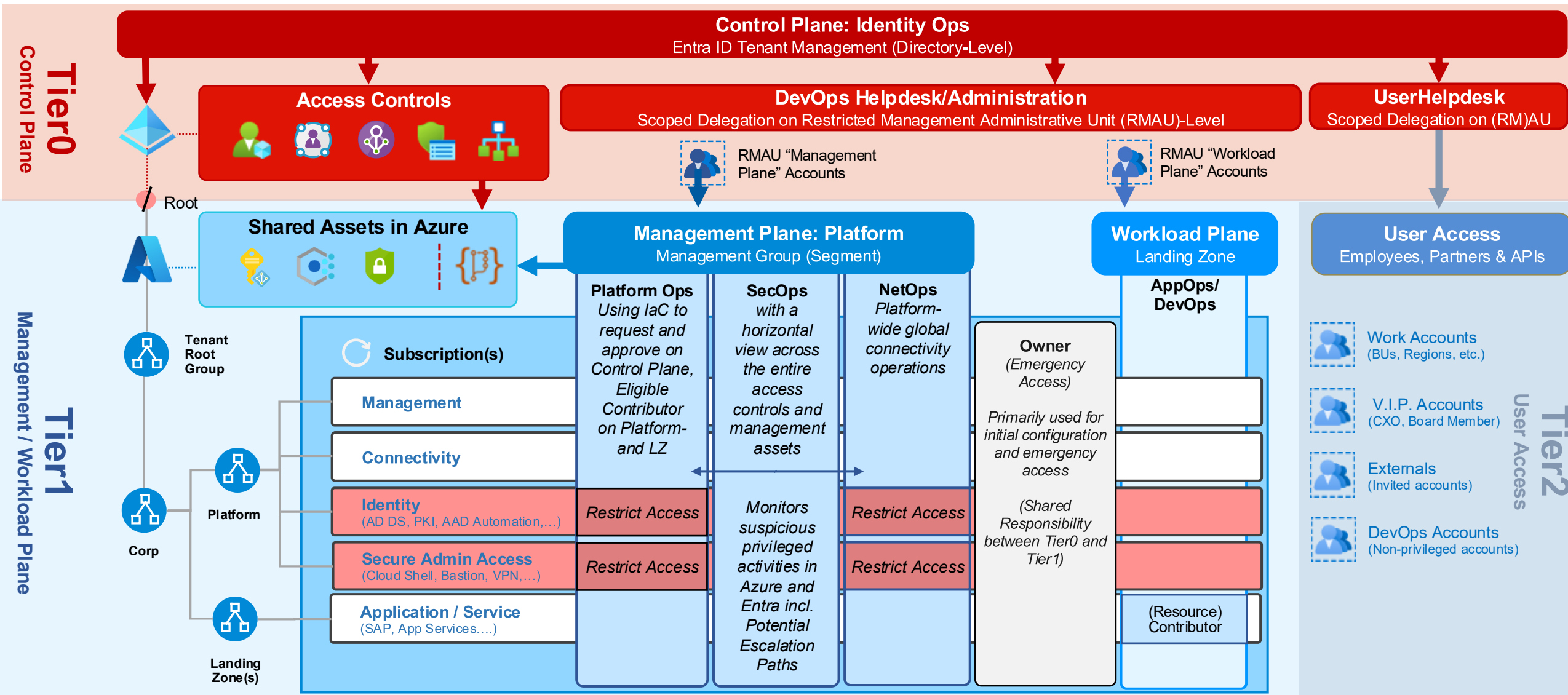
Attack Paths on Privileged Assets



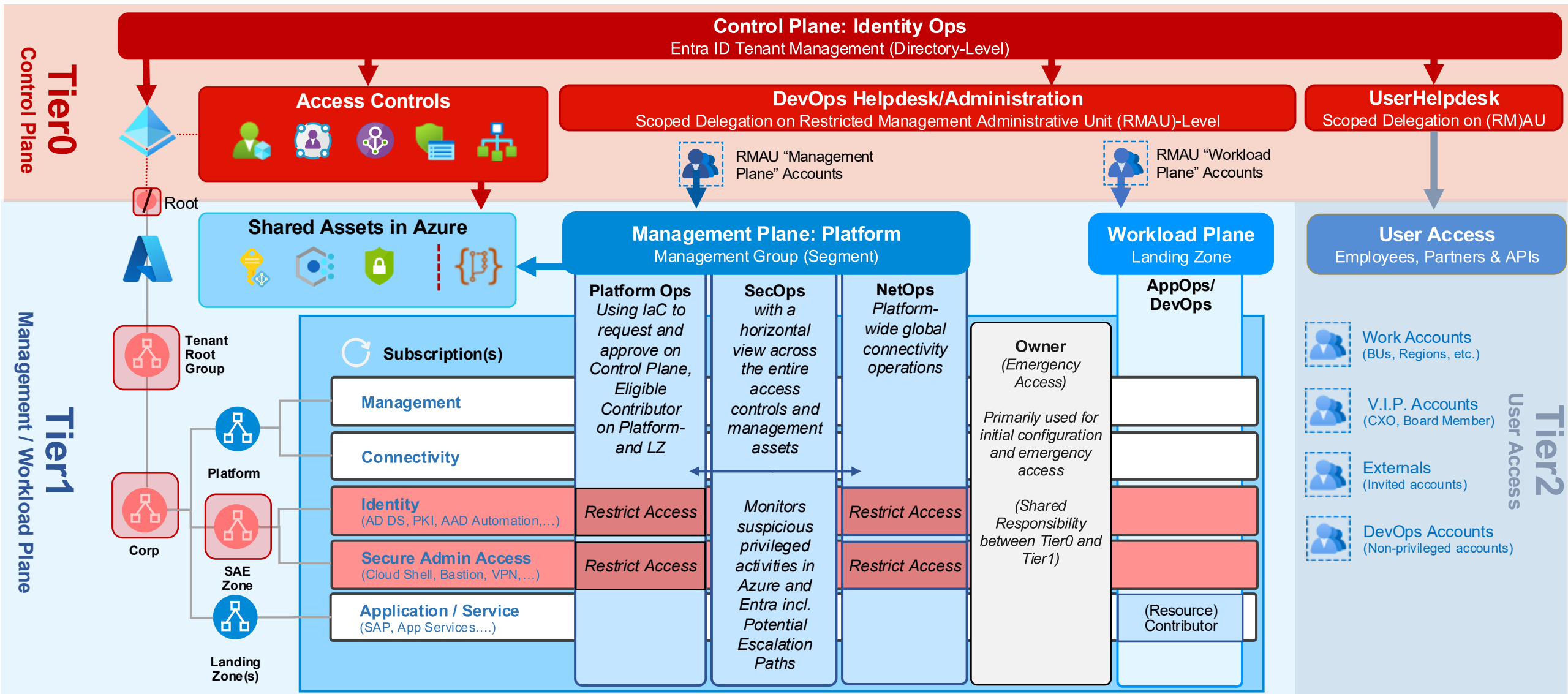
Attack Paths on Privileged Assets



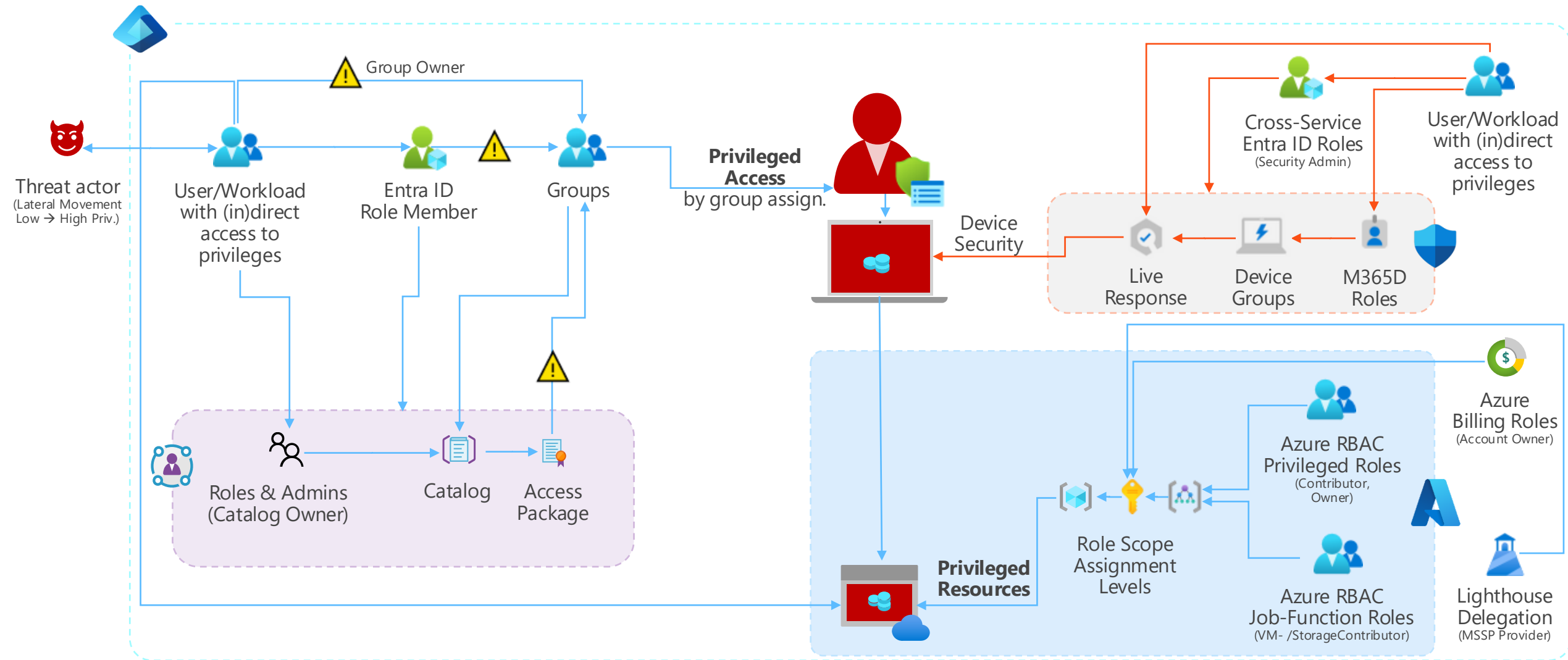
My approach on Enterprise Access Model



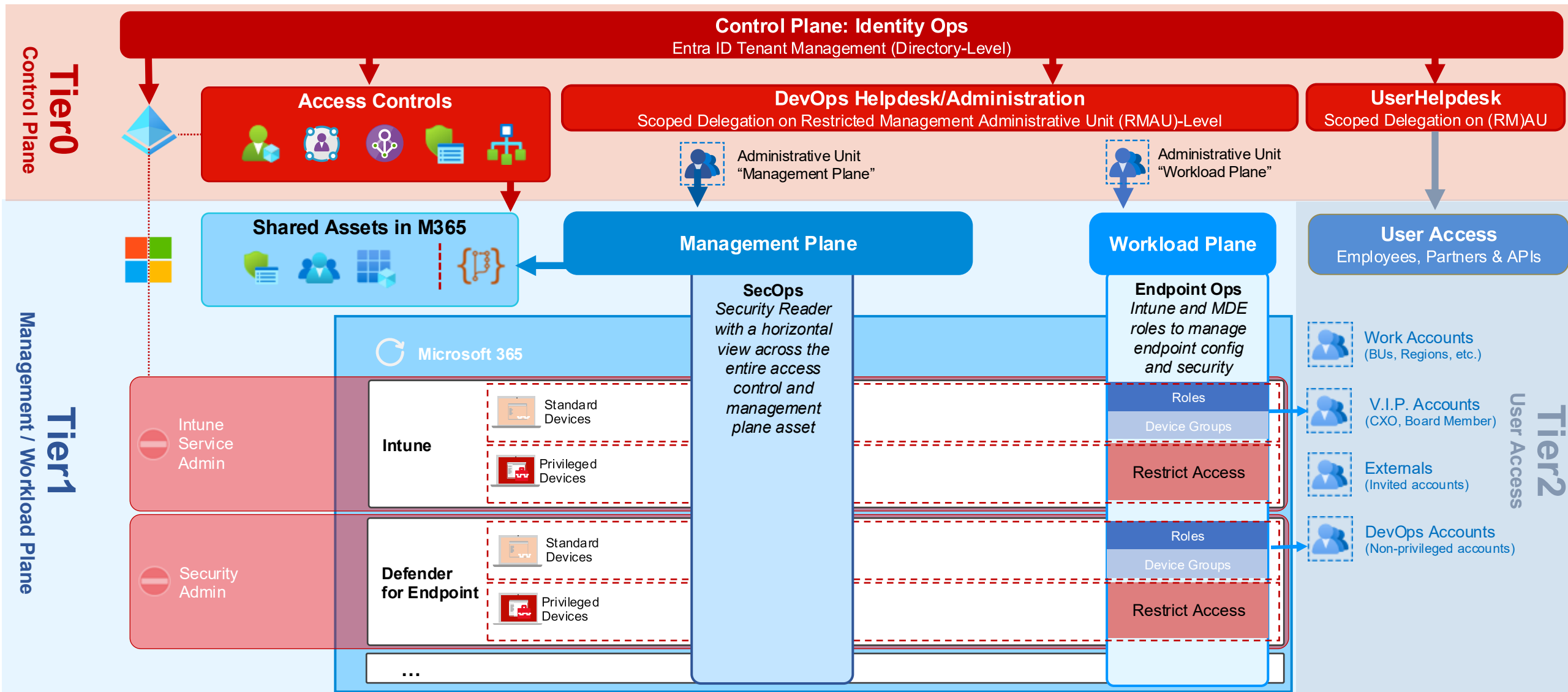
My approach on Enterprise Access Model



Attack Paths on Privileged Assets



My approach on Enterprise Access Model





Defining Tiering Levels As Code

Definition of Control Plane by Actions (and not Roles!) and Scope

```
"EAMTierLevelName": "ControlPlane",
"EAMTierLevelTagValue": "0",
"TierLevelDefinition": [
  {
    "Category": "Microsoft.AzureAD",
    "Service": "Privileged User Management",
    "RoleAssignmentScopeName": [
      "/",
      "/administrativeUnits/<AzureAdmin>",
      "/administrativeUnits/<M365Admin>"
    ],
    "RoleDefinitionActions": [
      "microsoft.directory/users/authenticationMethods/create",
      "microsoft.directory/users/authenticationMethods/delete",
      "microsoft.directory/users/authenticationMethods/basic/update",
      "microsoft.directory/users/create",
      "microsoft.directory/users/disable",
      "microsoft.directory/users/delete",
      "microsoft.directory/users/enable",
      "microsoft.directory/users/basic/update",
      "microsoft.directory/users/manager/update",
      "microsoft.directory/users/userPrincipalName/update",
      "microsoft.directory/users/invalidateAllRefreshTokens",
      "microsoft.directory/users/restore",
      "microsoft.directory/users/password/update"
    ]
  }
]
```

Defining Tiering Levels As Code

Definition of Actions and Scope

```
{
  "EAMTierLevelName": "ControlPlane",
  "EAMTierLevelTagValue": "0",
  "TierLevelDefinition": [
    {
      "Category": "Microsoft.AzureAD",
      "Service": "Privileged User Management",
      "RoleAssignmentScopeName": [
        "/",
        "/administrativeUnits/<AzureAdmin>",
        "/administrativeUnits/<M365Admin>"
      ],
      "RoleDefinitionActions": [
        "microsoft.directory/users/authenticationMethods/create",
        "microsoft.directory/users/authenticationMethods/delete",
        "microsoft.directory/users/authenticationMethods/basic/update",
        "microsoft.directory/users/create",
        "microsoft.directory/users/disable",
        "microsoft.directory/users/delete",
        "microsoft.directory/users/enable",
        "microsoft.directory/users/basic/update",
        "microsoft.directory/users/manager/update",
        "microsoft.directory/users/userPrincipalName/update",
        "microsoft.directory/users/invalidateAllRefreshTokens",
        "microsoft.directory/users/restore",
        "microsoft.directory/users/password/update"
      ]
    }
  ]
}
```

Classified Privileged Access of User

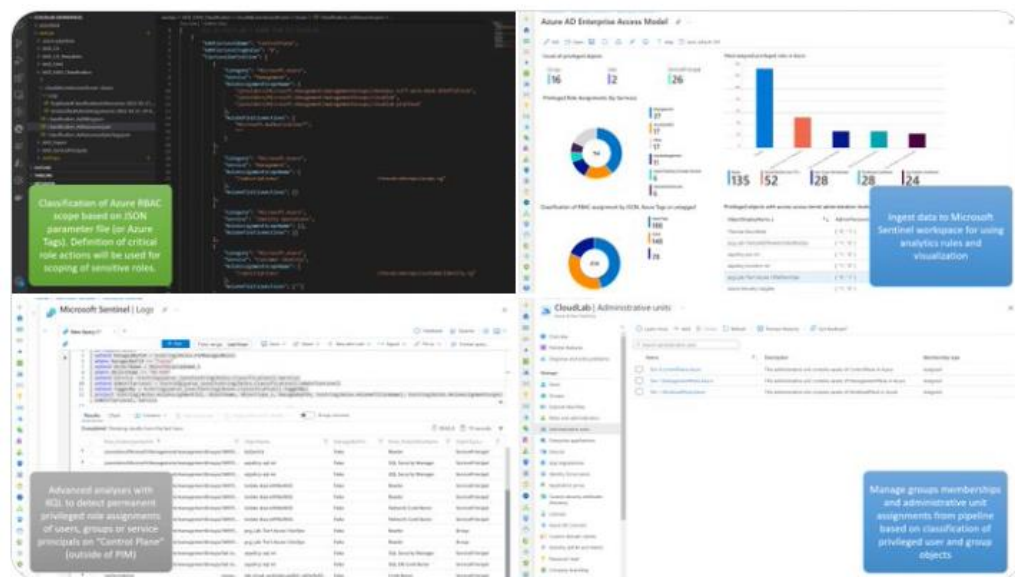
```
{
  "ObjectId": "ControlPlane",
  "ObjectType": "0",
  "ObjectDisplayName": "0",
  "Classification": [
    {
      "AdminTierLevel": "Microsoft.AzureAD",
      "AdminTierLevelName": "User Management",
      "Service": "Privileged User Management",
    }
  ],
  "RoleAssignments": [
    {
      "RoleAssignmentId": "18160c44-b052-45b3-9874-0f289d1d6cb4",
      "RoleAssignmentScopeId": "/administrativeUnits/<AzureAdmin>",
      "RoleAssignmentScopeName": "Tier0-ControlPlane.1.DevOps",
      "RoleAssignmentType": "Direct",
      "PIMAssignmentType": "Eligible",
      "RoleDefinitionName": "User Administrator",
      "RoleDefinitionId": "fe930be7-5e62-47db-91af-98c3a49a38b1",
      "RoleType": "BuiltinRole",
      "Classification": [
        {
          "AdminTierLevel": "0",
          "AdminTierLevelName": "ControlPlane",
          "Service": "Privileged User Management",
          "TaggedBy": "JSONwithAction"
        }
      ]
    }
  ]
}
```


Let's build a tool to identify/classify

How it started:

During the last weekends, I've started to work on my #AADOps PoC project to operationalize "Tiered Administration" (#EnterpriseAccessModel) in #Azure and #AzureAD.

Classification of privileged resources allows to monitor privilege escalation and protect sensitive accounts. (1/2)



9:52 AM · Mar 22, 2022

How it's going:

I am excited to release #EntraOps Privileged EAM today. This project allows to identify, classify and monitor your #MicrosoftEntra privileges automatically based on the "tiered administration" of the #EnterpriseAccessModel. Learn more and try it out: cloud-architekt.net/entraops/

EntraOps Privileged EAM
Community project to classify, identify and protect your privileges based on Enterprise Access Model (EAM)

- Automation for deployment in GitHub, support local execution or any platform which supports PowerShell Core
- Ingest classified privileges with detailed data to Log Analytics Workspace or Sentinel WatchList for hunting and enrichment.
- Identify privileged identities and access based on automated and full customizable classification of Enterprise Access "tiering" model
- Track changes of privileged assets "as Code" in repository and build queries or reports based on KQL or JSON output

3:51 PM · Jun 27, 2024

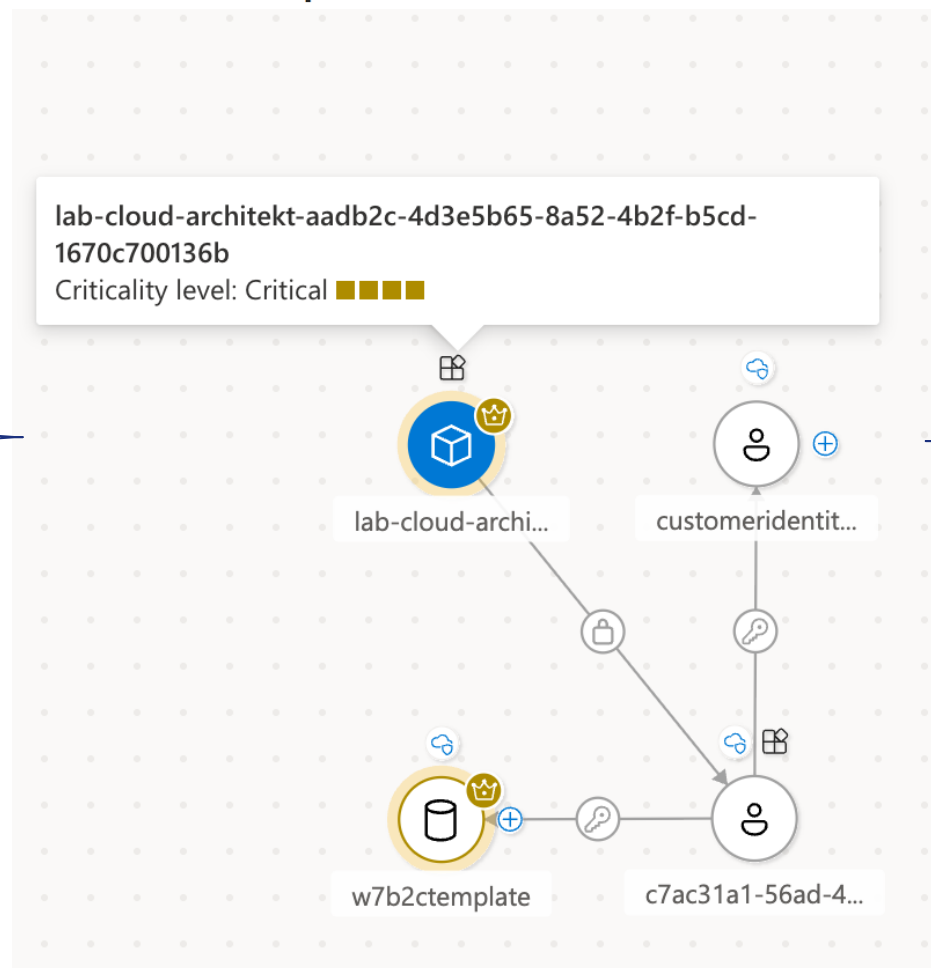
Integration with Critical Asset Management

Critical asset management

Manage the criticality level of your organization's assets, either according to predefined classifications

Classification	Assets	Criticality level
Predefined classifications (128)		
Domain Controllers	11	Critical
ADCS Servers	1	Critical
Domain Admin Workstations	11	Critical
Custom (8)		
PAW Devices	1	Critical
Control Plane Cloud resources	0	Critical
Control Plane resources	0	Critical
B2C Resources	11	Critical
Entra Connect Server Admins	1	Critical

Attack surface map



Control Plane Assets
(direct or indirect impact)

KQL query via
Advanced Hunting
API in Microsoft Graph



EntraOps Privileged EAM



Demo

Dynamic classification of roles and scopes, Identify privileges in RBACs

Steps to implement EAM with EntraOps



Classify

Adjusted classification template incl. critical scopes for your environment

Identify

Analyze role assignments and apply classification on roles and principals

Protect

Apply RMAU for unprotected privileges and assurance of CA coverage

Monitor

Ingest classification data to XDR/SIEM for monitoring on privileged assets & entity enrichment

Reporting

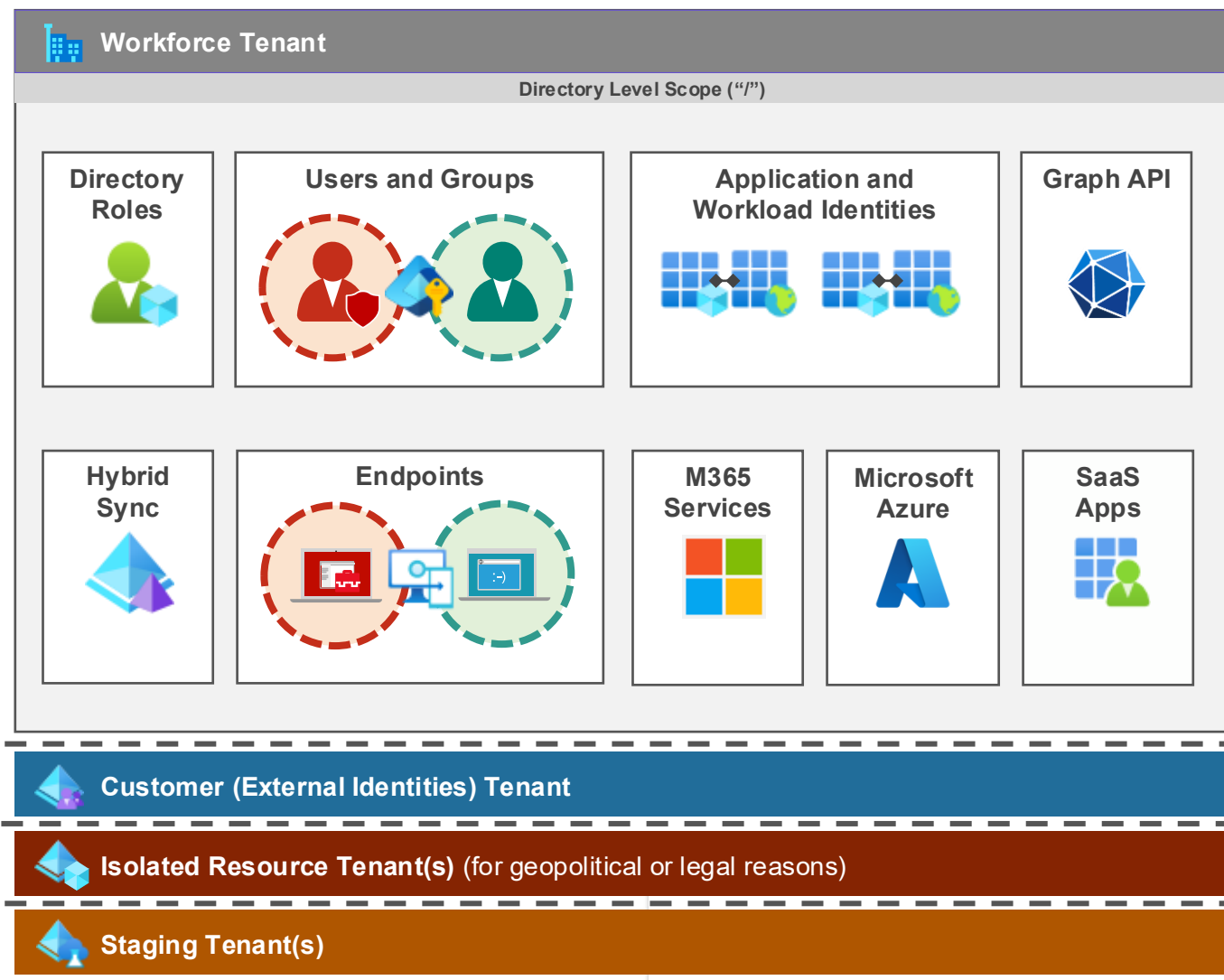
Tracking security posture and attack paths correlation with other signals and data sources



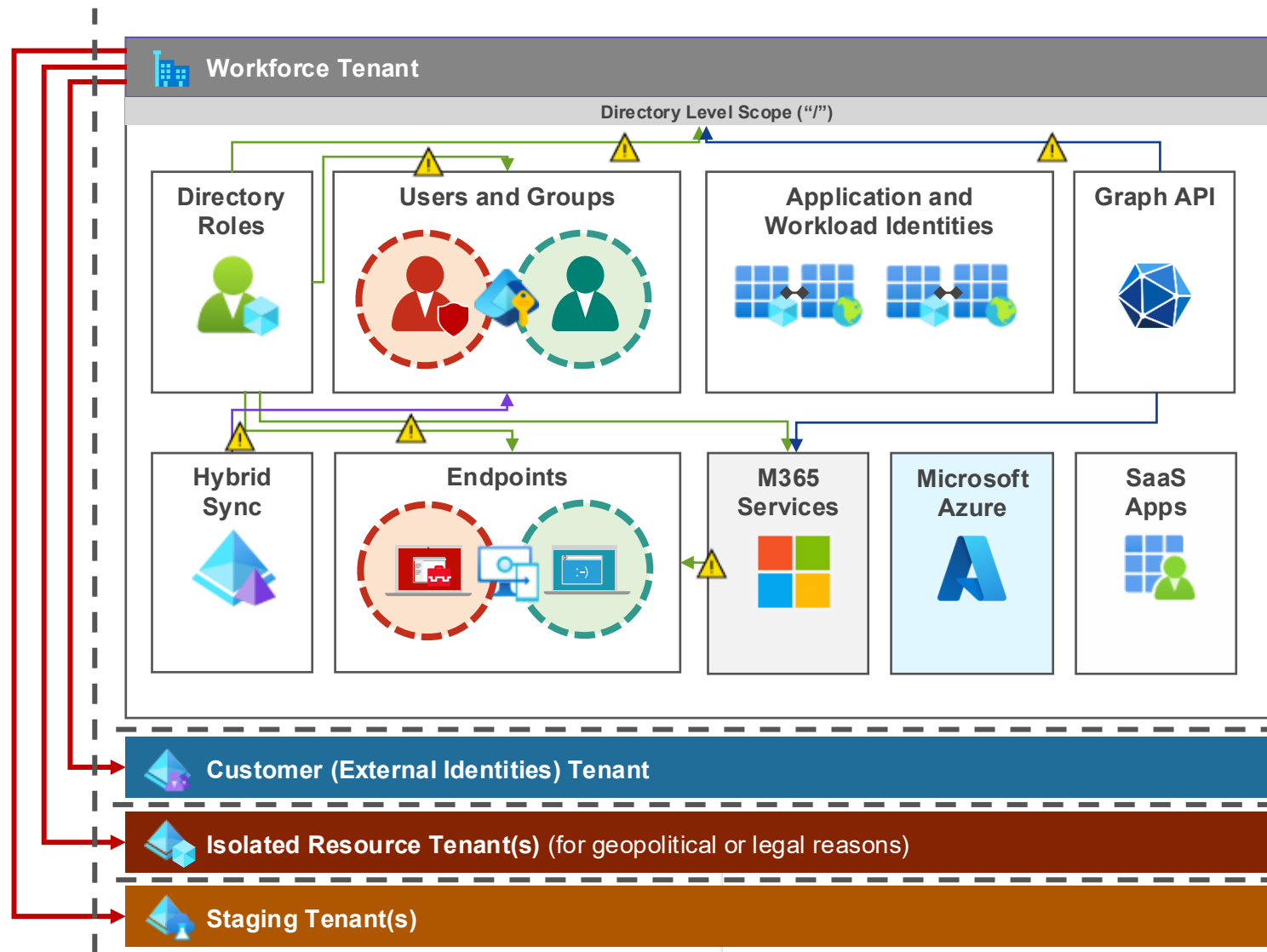
Demo

Reporting and Protection capabilities in EntraOps

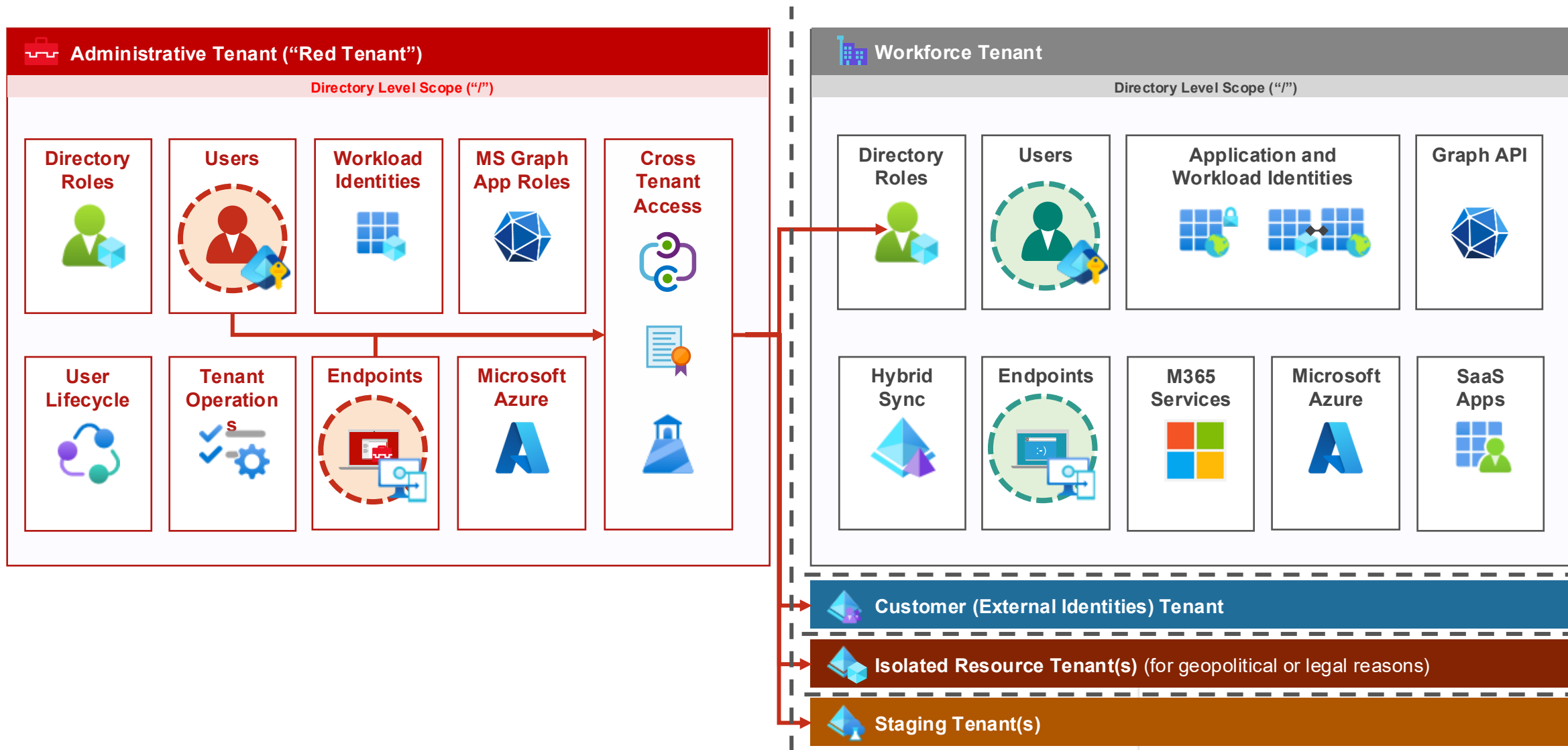
Intra-Tenant Isolation



Intra-Tenant Isolation

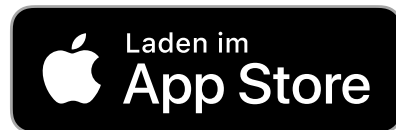


Inter-Tenant Isolation with Red Tenant





Bitte gebt uns euer Feedback in der App!



Vielen Dank!